

Data Leak Worksheet

Incident summary

A sales manager shared access to a folder of internal-only documents with their team during a meeting. The folder contained files associated with a new, unannounced product, along with customer analytics and promotional materials. After the meeting, the manager did not revoke access to the internal folder, but warned the team to wait for approval before sharing the promotional materials. During a later video call with a business partner, a sales representative intended to share a link to the promotional materials, but accidentally shared a link to the entire internal folder instead. The business partner then posted the link on their company's social media page, assuming it was the promotional materials.

Analysis

Control	Least privilege
Issue(s)	<i>What factors contributed to the information leak?</i> Least privilege was not enforced. The sales manager shared an entire internal folder with the team and never revoked access after the meeting, so users retained access they no longer needed. Because the whole folder was shared rather than only the promotional materials, a single mistaken link exposed unannounced product files and customer analytics to an external partner, who then posted it publicly.
Review	<i>What does NIST SP 800-53: AC-6 address?</i> AC-6 is the Least Privilege control in the Access Control family. It states that users should be granted only the minimum access and authorization needed to complete a task, and no more. Enforcing this through roles, accounts, and processes prevents users from operating at higher privilege levels than their work requires, which limits the damage an error or compromised account can cause.
Recommendation(s)	<i>How might the principle of least privilege be improved at the company?</i> 1. Restrict access to sensitive resources based on user role, so employees can only reach the specific files their job requires rather than an entire internal folder. 2. Automatically revoke access to information after a set period of time, so access granted for a meeting or task does not persist indefinitely.
Justification	<i>How might these improvements address the issues?</i> Role-based access would have limited the sales representative to only the promotional materials, so the mistaken link could not have exposed internal product or customer data. Automatic time-based revocation would have removed the team's access to the internal folder once the meeting ended,



closing the window in which the accidental share was even possible. Together they enforce least privilege and reduce the likelihood of another leak.